

Mapeo de Preguntas de la Encuesta a Requisitos Normativos

La siguiente tabla muestra, para cada bloque de preguntas, las principales referencias normativas y de buenas prácticas con las que se relaciona. El objetivo es facilitar el alineamiento con marcos como ENS, ISO 27001, NIS2, así como con las prácticas recomendadas por CWE y organismos internacionales.

Bloque / Pregunta	Tema principal	ENS (ES)	ISO 27001 / 27002	NIS2 / Directivas UE	Otros marcos / referencias
1.x Datos generales	Contexto organizativo y de sistemas	ENS – Título II (Ámbito de aplicación y principios básicos)	ISO 27001 – Cláusula 4 (Contexto de la organización)	NIS2 – Art. 2-3 (Ámbito y entidades esenciales/im portantes)	ENISA Threat Landscape (sectorización)
2.1 Uso de CWE como taxonomía	Adopción de marcos reconocidos	ENS – Principio de gestión de riesgos y seguridad integral	ISO 27001 – A.5.1 Políticas de seguridad	NIS2 – Requisitos de gestión de riesgos y medidas técnicas	CWE (MITRE) como referencia técnica global
2.2 Política interna de gestión de debilidades	Gobernanza y políticas	ENS – Política de seguridad (Título III)	ISO 27001 – A.5.1.1 Políticas de seguridad	NIS2 – Gobernanza de la ciberseguridad	Buenas prácticas de gobierno corporativo en ciberseguridad
2.3 Integración en la estrategia corporativa	Alineamiento estratégico	ENS – Coordinación y organización	ISO 27001 – Cláusula 5 Liderazgo	NIS2 – Responsabilidad de la dirección	Estrategia Nacional de Ciberseguridad
3.1 Métodos de identificación de debilidades	Procesos de identificación y pruebas	ENS – Medidas de protección (Técnicas y organizativas)	ISO 27002 – A.14.2 Seguridad en procesos de desarrollo	NIS2 – Requisitos técnicos de seguridad	OWASP, prácticas de testing, ENISA recomendaciones técnicas
3.2 Mapeo de vulnerabilidades a CWE	Clasificación estructurada	ENS – Análisis y gestión de riesgos	ISO 27002 – A.12.6 Gestión de vulnerabilidades técnicas	NIS2 – Gestión de vulnerabilidades	CWE-CVE mapeo oficial (MITRE)
3.3 Uso de métricas basadas en CWE	Métricas y reporting	ENS – Seguimiento continuo	ISO 27004 (medición de seguridad)	NIS2 – Supervisión y reporting	ENISA informes de métricas de ciberseguridad
3.4 Integración CWE/CVE/CVSS	Gestión integrada de vulnerabilidades	ENS – Gestión de incidentes y vulnerabilidades	ISO 27002 – A.16 Gestión de incidentes	NIS2 – Notificación de incidentes y vulnerabilidades	CVE, CVSS, CWE como tríada estándar
4.1-4.2 Uso del Top 25	Priorización de debilidades	ENS – Principio de proporcionalidad	ISO 27002 – Selección de controles según riesgos	NIS2 – Medidas proporcionadas a los riesgos	CWE Top 25 Methodology

4.3 Uso de KEV	Priorización por explotación activa	ENS – Gestión de incidentes y alertas	ISO 27002 – A.16.1.3 Comunicación de debilidades	NIS2 – Gestión de incidentes significativos	Catálogo KEV (CISA) y su mapeo a CWE
4.4 Uso de MIHW	Debilidades de hardware	ENS – Sistemas y comunicaciones	ISO 27002 – A.11 Seguridad física y de equipos	NIS2 – Sectores con componentes OT/ICS	CWE MIHW (Most Important Hardware Weaknesses)
5.x Métricas internas CWE	Indicadores de gestión	ENS – Supervisión continua y mejora	ISO 27004, ISO 27002 – A.18 Mejora continua	NIS2 – Evaluación de madurez y eficacia	ENISA – Métricas de ciberseguridad sectoriales
6.x Integración en SDLC	Seguridad en el desarrollo	ENS – Medidas de desarrollo y evolución de sistemas	ISO 27002 – A.14 Desarrollo seguro	NIS2 – Medidas técnicas “state of the art”	CWE-1000 Research Concepts, OWASP SAMM
7.1 Debilidades en análisis de riesgos	Gestión de riesgos	ENS – Análisis y gestión de riesgos	ISO 27005 Gestión de riesgos	NIS2 – Gestión de riesgos de ciberseguridad	ENISA – Risk Management Guidelines
7.2 Mapeo a ENS e ISO	Alineamiento normativo	ENS – Conjunto completo de requisitos	ISO 27001 – Controles Anexo A	NIS2 – Requisitos mínimos comunes	Guías CCN-CERT, ENS de detalle
7.3 Reporte a alta dirección	Reporting y gobierno	ENS – Responsabilidad de la dirección	ISO 27001 – Cláusula 5 Liderazgo	NIS2 – Responsabilidad del órgano de gestión	Buenas prácticas de gobierno corporativo
8.x Formación y cultura	Capacidades y concienciación	ENS – Formación y concienciación del personal	ISO 27002 – A.7 Concienciación	NIS2 – Capacidades y formación	Estrategias nacionales de capacidades en ciberseguridad
9.x Repositorios y datos	Gestión de la información de seguridad	ENS – Registro y monitorización	ISO 27002 – A.12.4 Registro y monitorización	NIS2 – Gestión de registros y reporting	ENISA – Gestión de datos de incidentes
10.1–10.4 Impacto y ROI	Dimensión económica y eficiencia	ENS – Principio de eficacia y eficiencia	ISO 27001 – Mejora continua	NIS2 – Evaluación de costes y beneficios	Modelos de riesgo actuarial, estudios de coste de incidentes

11.x Comentarios abiertos	Mejora continua y retroalimentación	ENS – Mejora continua	ISO 27001 – Cláusula 10 Mejora	NIS2 – Evolución del marco de seguridad	Investigación y desarrollo en ciberseguridad
--	---	--------------------------	--------------------------------------	--	--

Nota: El mapeo tiene carácter orientativo y no pretende sustituir a interpretaciones oficiales. Facilita, sin embargo, la trazabilidad entre la encuesta y los marcos regulatorios relevantes.